סיכום עיבוד המידע: מה המוצר שומר, איפה, ומי מקבל (אנגלית, המקור)

מסמך	סיכום עיבוד המידע: מה המוצר שומר, איפה, ומי מקבל (אנגלית, המקור)
נתיב המקור	docs/privacy/en/01-data-processing-summary.md
גרסת המקור	origin/main @ b6eb212ec
הוכן לחבילה	2026-10-24
מצב	הנוסח המקורי נשמר ללא שינוי; עיצוב בלבד. טיוטה לבדיקת עורך דין, אינו ייעוץ משפטי.

נוסח אנגלי: המקור, והעברי (01) עוקב אחריו סעיף אחר סעיף. הנוסח העברי נמצא באותה תיקייה.

---

01 - Data-processing summary: what SmplWise Arx stores

Status: DRAFT for the organisation and its counsel. Not legal advice and not a statement of legal compliance. Facts verified by reading the code and migrations of `origin/integ/290` @ `018795f96` (2026-10-19). Paths are relative to the repository root; `B/` below stands for `smplwise_vms/backend/smplwise/`. Every statement that needs a lawyer is marked **REQUIRES COUNSEL REVIEW** and carries an id (C1, C2, ...); the full list is in `../README.md`.

1. Where the data lives

- SmplWise Arx runs as a Home Assistant add-on on a server at the customer's site. Its database is one local SQLite file, `smplwise.db`, in the add-on data directory (`B/config.py`: `data_dir / "smplwise.db"`; the add-on mounts `/data`). Other files sit beside it: plan images, ticket photos and invoice files (`<data>/tickets/<ticket id>/`, `B/services/tickets/deletion.py`), event thumbnails (`<data>/thumbs`, `B/services/thumbnails.py`) and project backups (`<data>/backups`, `B/services/backup.py`).
- The code contains no feature that copies the database to a SmplWise-operated server. Parts of the product talk to outside services (section 5). Where the host server, its disk and its off-site backups are is a deployment matter this repository does not show: **REQUIRES COUNSEL REVIEW (C8)**.
- Who is the "database owner / controller / holder / processor" for each category (the organisation operating the building, SmplWise as the software supplier, others) is a legal question this document does not answer: **REQUIRES COUNSEL REVIEW (C1)**.

2. Categories of personal data

"Table" names are SQLite tables; "mig" is the migration file under `B/migrations/` that defines them.

#	Category	Data subjects	Fields kept (verified)	Table / mig	Switch
A	Operator accounts	staff who sign in	user id, username, display name, source, optional e-mail, administrator note, first/last seen, disabled/deleted marks; password hash (PHC string), sign-in time and masked address, sessions (hashed cookie, masked IP, country, user agent <= 200 chars, device label), first-login/reset links (hash only), passkeys, TOTP, link to the Home Assistant user	`users`, `auth_local_*`, `auth_webauthn_credentials`, `auth_totp*`, `identity_links`, `remote_access_users`, `remote_sign_ins` / mig 0001, 0096, 0098, 0033, 0035	always
B	Audit log	operators, and `contact:<id>` actors	time, actor user id and username, action, resource type/id, decision, reason, request id, details (ids and counts; see the privacy rule in `B/services/tickets/deletion.py`: no names, phones or content for ticket deletion)	`audit_log` / mig 0001	always
C	Directory of external people	vendors, technicians, contacts, employees (kind `person`, `vendor`)	display name, company, phone (E.164), keyed phone index, e-mail, preferred channel, language, notes, active flag, creator, last assignment, phone-confirmation time and method, department access	`ticket_contacts`, `ticket_contact_departments`, `ticket_phone_verifications` / mig 0080, 0084, 0091, 0111	`tickets.enabled`
D	Tickets	requesters, handlers, vendors, anyone named in free text	title, description, place text, creator id and name, device/place, status history (events with actor name and note text), photos (file path, hash, size, uploader), assignments (frozen assignee name), cost claims and invoice files, quotes/RFQ (vendor, files, messages), outbound/inbound message log (keyed sender index, no number), link access log (time, kind, client key)	`tickets`, `ticket_events`, `ticket_attachments`, `ticket_assignments`, `ticket_cost_*`, `ticket_rfq*`, `ticket_outbox`, `ticket_inbound`, `ticket_link_access` / mig 0079-0117	`tickets.enabled`
E	Technician door access	external technicians sent by vendors	see section 3	`access_*` / mig 0107, 0108, 0112	`access.external_grants` (off)
F	People messaging (WhatsApp from the people screen)	people known to the door system	recipient id (the door system's id), sender user id and name snapshot, template id/label, text length (not the text), outcome, keyed phone hash, station ids; opt-out list; consent-by-link rows (notice version, no number)	`intercom_messages`, `intercom_message_optout`, `intercom_consent*`, `intercom_held_messages` / mig 0076, 0113, 0114	settings

#	Category	Data subjects	Fields kept (verified)	Table / mig	Switch
G	Phone-app presence	staff who install the phone app	device name/platform/model/app+OS version, hashed device token, notice-acknowledgement version/time, current presence (inside/outside, site, one latitude/longitude with accuracy), event log (enter/exit/fix/sensor values with coordinates), push token (opaque relay token), muted categories	`mobile_devices`, `mobile_presence_events`, `mobile_push_messages` / mig 0057	`presence.*` master switch, default OFF (`B/services/presence.py`)
H	Camera event pictures	people who appear in camera frames	one JPEG per event grabbed from the NVR recording at event time; event type, camera id, times	files under `<data>/thumbs`, `events` / mig 0003	events feature
I	Notifications	operators	in-app inbox rows, delivery log, browser push subscriptions (endpoint, keys, user agent)	`notifications`, `notification_deliveries`, `push_subscriptions` / mig 0034, 0046	always
J	Backups	all of the above that are exported	see section 4	`<data>/backups/*.zip`	daily + before upgrade

Not analysed here: video recordings (they stay on the NVR / Frigate, never in Arx backups - `B/services/backup.py` docstring), the energy-metering module, and device telemetry. Whether camera/video surveillance duties apply is **REQUIRES COUNSEL REVIEW (C13)**.

3. Technician door access (category E) in detail

The feature lets a vendor tell Arx which technicians will come, and lets an authorised manager approve a time-limited personal entry code issued in the building's door system ("WisKey"). It is **off** (`access.external_grants` default `off`) and cannot be turned on in this build: `GO_LIVE_PERMITTED = False` in `B/services/access_grants.py` makes the engine refuse every call and the WhatsApp transport send nothing. Every value below describes what the code would do once that permit is given.

What is stored in Arx:

- The vendor types a name (<= 60 chars after normalisation in `B/services/access_arrival.py`) and a phone number. A technician added from the arrival page is saved at once as an inactive directory row (`ticket_contacts.active = 0`) plus a row in `access_pending_contacts` (vendor id, assignment id, creator `contact:<id>`, creation time, acceptance/rejection time). So the name and phone exist in Arx before any manager has seen them.
- The phone number is kept as digits and as a keyed hash (`phone_key`) used for rate limits; the cap ledger `access_code_sends` holds the keyed hash, time and outcome, never the number or the code, and is deleted after 2 days.
- The grant (`access_grants`): subject (`contact` id), source (manual / ticket / RFQ order), doors per station, validity window (at most 14 days, `MAX_DAYS_CAP`), optional daily hours, state, who requested and approved and when, code send state and counters, end reason. Ids only: no name, phone, code or message text.

- The notice acknowledgement (`access_grant_notices`): notice version (`n2`), via (`page` = the vendor ticked, `approver` = the manager ticked "the person was told"), who and when. The acknowledgement is by the vendor or manager, not by the technician.
- The link to the door-system person (`access_person_links`): door-system person id, origin, employee number Arx generated (`x` + 12 hex), who linked and when.

What is sent to the door system (`B/services/access_grant_engine.py`, `create_payload`): display name (first 32 chars), a random employee number, category (contractor / visitor), "responsible person" (the approver's name, <= 64 chars), a fixed access purpose (<= 128 chars), validity, door map and timing; the personal 6-digit code is generated for the person in the door system. The phone number is **not** sent (`phone` "is simply not sent"). The door system records each entry under the person's name, time and door; whether it also stores a picture at entry and for how long is decided on the door-system side and was not verified: **REQUIRES COUNSEL REVIEW (C7)** (and a technical confirmation from the door-system operator).

What is sent to the technician: one WhatsApp message to the number the technician confirmed (confirmation no older than `access.external.phone_fresh_days`, default 180) with the code, door names, dates/hours and a reference (`TEMPLATES` in `B/services/access_grants.py`). The message names the product ("SmplWise Arx"), not the organisation.

What is never stored in Arx: the personal code (not hashed, not its length), in any table, log or error text; an ID number, e-mail or picture of the technician; message text. The audit rows of this feature carry ids and counts (`_audit` in `B/services/access_grants.py`).

Notice shown (`NOTICE_TEXT`, version `n2`, he/en/ar/ru): says the name and phone number are kept, each entry's time and door (and, where enabled, a picture), the purposes, that the information is kept "until the organisation deletes it, in line with its retention policy" (this is why `06-retention-policy-template.md` exists), that providing the details is not legally required but no code can be issued without them, and that requests go to "the building manager". Whether this wording is sufficient: **REQUIRES COUNSEL REVIEW (C2, C3)**.

4. Backups

`B/services/backup.py`: a zip of the "project tables" (settings, sites/buildings/floors, plans, cameras, saved views, notification settings, energy module, ...) and the access tables (`ACCESS_TABLES`: users, local credentials, passkeys, groups, bindings, ...), optionally the audit log and events. Password hashes and HMAC keys travel only inside the section encrypted with the administrator's backup password. The ticket tables (contacts, tickets, access grants) are **not** in `PROJECT_TABLES`; the code comment says they are "operational data". Automatic backups kept: 5 "pre-upgrade" and 7 "daily" (`KEEP`); manual and uploaded ones are never removed by the code. A backup taken before a deletion still contains the deleted rows if the deleted rows were in scope; for tickets nothing extra is done (`B/services/tickets/deletion.py` docstring). Where the zip files are copied afterwards is outside the code: **REQUIRES COUNSEL REVIEW (C8)**.

5. Recipients and outside services

Service	What goes there	Evidence	Note
WhatsApp	recipient phone and message text of ticket links, verification codes, people messages, technician entry codes	`B/services/messaging_accounts.py`, `B/services/tickets/channel_whatsapp.py`, `B/services/access_grants.py` `send_code`	sent through a Home Assistant WhatsApp integration (`ha-whatsapp`, platform `whatsapp`) from the organisation's own WhatsApp account; the existing legal brief records it as an unofficial component. Meta processes message metadata. **REQUIRES COUNSEL REVIEW (C5)**
Cloudflare tunnel	traffic of the remote channel and of the public vendor/handler pages (ticket links, vendor portal, RFQ links, arrival page); TLS ends at Cloudflare	`B/remote_channel.py`, `B/config.py`, `B/services/tickets/public_app.py`	names/phones typed on public pages pass through it. **REQUIRES COUNSEL REVIEW (C6)**
Door system (WisKey)	person record and grants (section 3)	`B/services/access_grant_engine.py`	on-site system; its own retention and any outside maintainer's access are not visible here. **REQUIRES COUNSEL REVIEW (C7)**
Push relay (phone app)	an opaque relay token and a generic push; the real title/body is fetched by the app from Arx with its device token (24 h expiry)	mig 0057 comments, `B/config.py` `push_relay_url`, `B/services/mobile_push.py`	relay operator and location not shown in this repository. **REQUIRES COUNSEL REVIEW (C9)**
Browser web push	endpoint and keys of the browser's push service	`B/services/push.py`	provided by the user's browser vendor
E-mail (SMTP)	notification and ticket e-mails if configured	`B/services/notify_email.py`, `B/services/tickets/channel_email.py`	off unless configured
Home Assistant	user identity (Ingress), entities/devices/areas, and the WhatsApp integration	`docs/security/HA_IDENTITY_RBAC_HE.md`	the host administrator can reach data outside Arx's own access control (same document, section 2)

6. Security measures present in the code (facts, not an assurance)

Role-based access control with scoped permissions (`B/rbac.py`, `docs/security/HA_IDENTITY_RBAC_HE.md`); every write audited; hashed tokens and sessions; rate limits on codes and links; fixed code-owned message texts; phone numbers never in audit rows or logs (`B/services/tickets/contacts.py` docstring); public pages answer a uniform 404 on any failure (`docs/security/TICKETS_PUBLIC_SURFACE_REVIEW_CHECKLIST.md`); dependency and secrets audit in `docs/security/DEPENDENCY_AND_SECRETS_AUDIT.md`. Whether these measures satisfy any legal security standard: **REQUIRES COUNSEL REVIEW (C4)**.